emsi

École Marocaine des Sciences de l'Ingénieur



CHAPITRE 3

Le RGPD : protéger les données personnelles

Module 1 · Introduction à l'IA et éthique de l'IA · 4e année ingénierie informatique

OBJECTIFS PÉDAGOGIQUES

À la fin de ce chapitre, vous serez capable de…

Situer le RGPD

expliquer pourquoi il existe, à qui et où il s'applique, y compris aux entreprises marocaines.

Qualifier une donnée

distinguer donnée personnelle, donnée sensible, donnée pseudonymisée et donnée anonyme.

Contrôler un traitement

vérifier qu'il respecte les sept principes et repose sur une base légale.

Garantir les droits

reconnaître le droit qu'invoque une personne et la réponse attendue de l'organisation.

Organiser la conformité

rôles (responsable, sous-traitant, DPO), registre, AIPD, notification en 72 h, sanctions.

PLAN

Les six sections du chapitre



1 · Le cadre

Pourquoi, pour qui, où ?



2 · Les données

Personnelles, sensibles, anonymes



3 · Les risques

Quand les données se retournent contre nous



4 · Les principes

Sept règles d'or et six bases légales



5 · Les droits

Ce que chacun peut exiger



6 · Responsabilités

Acteurs, outils, sanctions

POUR COMMENCER

Une matinée ordinaire : combien de traces laissez-vous ?

7 h 00 — **Réveil**
le téléphone enregistre votre position

7 h 45 — **Tramway**
la carte d'abonnement valide votre trajet

8 h 10 — **Café**
paiement par carte bancaire

8 h 30 — **Entrée à l'école**
badge et caméra de vidéoprotection

9 h 00 — **Cours**
connexion au Wi-Fi : identifiant de l'appareil

9 h 15 — **Pause**
la montre connectée mesure votre rythme cardiaque

Avant 9 h 30, au moins six organisations ont déjà traité vos données personnelles.
Qui fixe les règles ? Que peuvent-elles en faire ? Quels sont vos droits ?

1

SECTION 1

Le RGPD : pourquoi, pour qui, où ?

« Vos données valent de l'or : qui les protège ? »

Introduction au RGPD

DÉFINITION

Règlement général sur la protection des données

Règlement (UE) 2016/679, adopté le 27 avril 2016 et entré en application le 25 mai 2018. Il fixe les règles de collecte et d'utilisation des données personnelles dans l'Union européenne.

JOUE, L 119, 4 mai 2016

EN D'AUTRES TERMES

Le RGPD dit ce qu'une organisation a le droit de faire avec des informations qui concernent une personne.

Pourquoi remplacer la directive de 1995 ?

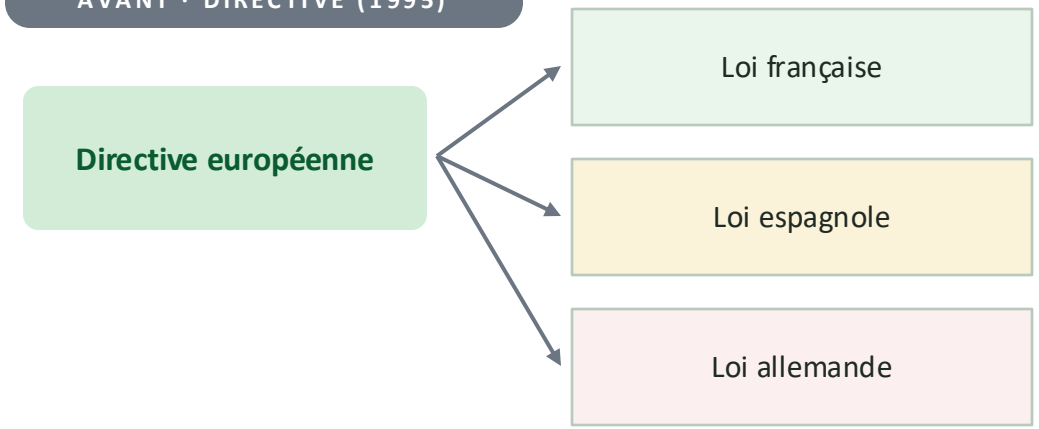
Elle était devenue insuffisante dans un monde dominé par :

- Réseaux sociaux
- Smartphones
- Objets connectés
- Intelligence artificielle
- Big Data



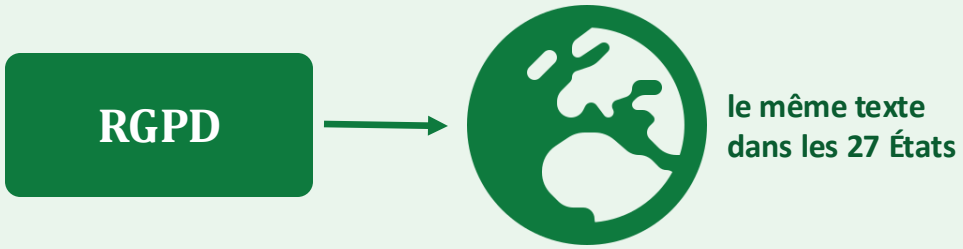
Un règlement, pas une directive : pourquoi c'est important

AVANT · DIRECTIVE (1995)



Chaque pays transpose à sa façon → des règles différentes d'un pays à l'autre.

DEPUIS 2018 · RÈGLEMENT



Applicable directement, sans transposition → les mêmes règles pour tous, partout dans l'UE.

À RETENIR

Le RGPD est un règlement : il s'applique automatiquement dans tous les pays de l'UE. Les États ne gardent que quelques marges, par exemple l'âge du consentement numérique (entre 13 et 16 ans).

Les quatre objectifs du RGPD

Renforcer les droits

des individus sur leurs données

ex. : droit à l'effacement, droit à la portabilité

Responsabiliser

les organisations qui collectent ou utilisent des données

ex. : prouver sa conformité (accountability)

Harmoniser

les règles dans toute l'Europe

ex. : un seul texte pour 27 pays

Sécuriser

l'environnement numérique

ex. : signaler toute fuite de données en 72 h

Objectif d'ensemble : restaurer la confiance des citoyens dans le numérique.

Champ d'application : à qui s'applique le RGPD ?

Critère d'établissement · art. 3.1

L'organisation est établie dans l'UE, même si le traitement a lieu ailleurs.

ex. : une banque française dont les serveurs sont hébergés au Maroc

Critère de ciblage · art. 3.2

L'organisation est hors UE, mais propose des biens ou services à des personnes qui se trouvent dans l'UE, ou suit leur comportement.

ex. : un site marocain de vente en ligne qui livre en France

Quel que soit le statut de l'organisation…



Entreprise · École · Association · Hôpital · Administration · Site web

…et pour tout traitement : collecte, stockage, envoi, analyse, suppression.

PIÈGE À ÉVITER

Ce n'est pas la nationalité qui compte, mais le lieu où se trouve la personne : un touriste marocain à Paris est protégé par le RGPD. Seule exception : l'usage purement personnel (votre carnet d'adresses).

Qu'est-ce qu'un « traitement » de données ?

DÉFINITION

Traitement · art. 4.2

Toute opération appliquée à des données personnelles, automatisée ou non : collecte, enregistrement, conservation, consultation, utilisation, transmission, effacement…

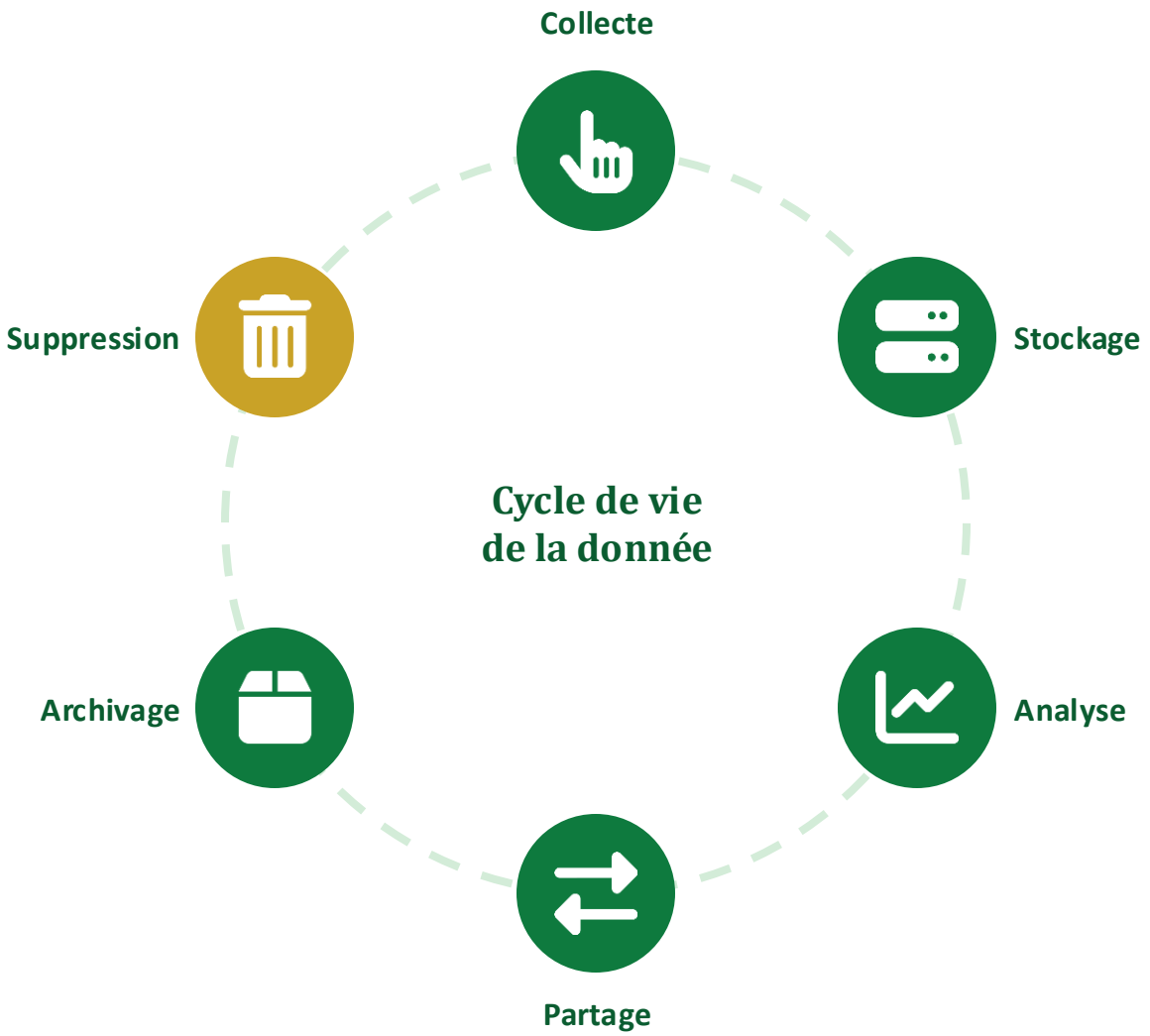
RGPD, article 4, point 2

EN D'AUTRES TERMES

Dès que l'on touche à une donnée personnelle, du premier clic à la suppression, on la « traite ».

EXEMPLE

Un simple fichier Excel des inscrits à un club est un traitement : le RGPD s'applique.



Et au Maroc ? La loi 09-08 et la CNDP

	RGPD (Union européenne)	Loi n° 09-08 (Maroc)
Texte	Règlement (UE) 2016/679, applicable en 2018	Loi du 18 février 2009 (dahir n° 1-09-15)
Autorité	Une autorité par pays (CNIL en France…)	CNDP (Commission nationale de contrôle de la protection des données à caractère personnel)
Logique	Responsabilisation : documenter et prouver sa conformité	Formalités préalables : déclaration ou autorisation de la CNDP
DPO	Obligatoire dans certains cas	Non prévu par la loi
Fuite de données	Notification à l'autorité sous 72 h	Pas de délai légal fixé
Sanctions	Jusqu'à 20 M€ ou 4 % du CA mondial	Amendes de 10 000 à 300 000 DH (doublées pour une personne morale), voire prison

Une entreprise marocaine doit souvent respecter les deux textes

Centre d'appels pour une banque française

il agit comme sous-traitant d'une organisation européenne

Site qui vend à des clients en Europe

critère de ciblage (art. 3.2)

ACTUALITÉ

Une refonte de la loi 09-08, pour l'aligner sur le RGPD, est en discussion.

QUIZ · CHAMP D'APPLICATION

Une start-up de Casablanca vend des cosmétiques en ligne et livre des clientes à Paris. Le RGPD s'applique-t-il ?

Non : elle est au Maroc

Oui : elle cible des personnes dans l'UE

Seulement si ses serveurs sont en Europe

Réponse Oui, par le critère de ciblage (art. 3.2) : elle propose ses produits à des personnes qui se trouvent dans l'UE. La loi 09-08 s'applique aussi, puisque les données sont traitées au Maroc.

2

SECTION 2

Données personnelles et données sensibles

« Mon adresse IP dit-elle qui je suis ? »

Qu'est-ce qu'une donnée personnelle ?

DÉFINITION

Donnée personnelle · art. 4.1

Toute information se rapportant à une personne physique identifiée ou identifiable, directement ou indirectement.

RGPD, article 4, point 1

EN D'AUTRES TERMES

Toute information qui permet de retrouver quelqu'un, seule ou combinée à d'autres.

LE SAVIEZ-VOUS ?

Code postal + date de naissance + sexe suffisent à identifier 87 % des Américains (Sweeney, 2000).

Exemples



Nom, prénom

identifie directement



E-mail, téléphone

identifie directement



Adresse IP, identifiant

identifie par recoupement



Empreinte, visage

identifie directement



Données bancaires

identifie par recoupement



Données médicales

identifie par recoupement



Historique d'achat

identifie par recoupement



Géolocalisation

identifie par recoupement

Donnée personnelle ou non ? Exemples et contre-exemples

LE BON CRITÈRE

La question n'est pas « contient-elle un nom ? », mais « permet-elle de retrouver une personne, seule ou par recoupement ? ».

PIÈGE À ÉVITER

Une donnée « professionnelle » reste personnelle : l'e-mail nominatif d'un salarié, son badge ou ses horaires de connexion sont protégés par le RGPD.

prenom.nom@entreprise.ma
e-mail nominatif d'un salarié
✓ Personnelle

contact@entreprise.ma
adresse générique de l'entreprise
✗ Non

Plaque d'immatriculation
le propriétaire est retrouvable
✓ Personnelle

Voix enregistrée d'un client
elle identifie la personne
✓ Personnelle

Température moyenne à Rabat
aucune personne concernée
✗ Non

Effectif par filière (agrégé)
statistique sans individu identifiable
✗ Non

Pseudonymiser n'est pas anonymiser

Données d'origine

Nom	Ville	Diagnostic
Salma B.	Fès	Diabète
Youssef K.	Fès	Asthme
Imane T.	Tanger	Diabète

Pseudonymisées

ID	Ville	Diagnostic
4F7A	Fès	Diabète
9C2E	Fès	Asthme
1B8D	Tanger	Diabète

Le nom est remplacé par un code ; la table de correspondance existe quelque part.

→ reste une donnée personnelle : le RGPD s'applique

Anonymisées

Région	Taux de diabète
Fès-Meknès	8,1 %
Tanger-Tétouan	7,6 %

Statistiques agrégées : impossible de revenir à une personne.

→ n'est plus une donnée personnelle : hors RGPD

PIÈGE À ÉVITER

Supprimer le nom ne suffit pas : ville + date de naissance + diagnostic peuvent suffire à retrouver la personne.

POUR L'INGÉNIEUR IA

Entraîner un modèle sur des données pseudonymisées reste un traitement soumis au RGPD.

Les données sensibles : une protection renforcée

DÉFINITION

Données sensibles · art. 9

Catégories particulières de données dont le traitement est en principe interdit, car il expose à de graves discriminations.

RGPD, article 9

POUR L'INGÉNIEUR IA

Un modèle peut déduire une donnée sensible à partir de données banales (la santé à partir des achats) : cette inférence est elle aussi encadrée.



Santé



Biométrie (si elle sert à identifier)



Génétique



Origine raciale ou ethnique



Convictions religieuses ou philosophiques



Opinions politiques



Appartenance syndicale



Vie ou orientation sexuelle

INTERDIT PAR PRINCIPE

sauf exceptions :

- consentement explicite
- médecine et soins
- intérêt public (santé publique…)
- droit du travail

QUIZ · DONNÉES SENSIBLES

Lesquelles sont des données sensibles au sens de l'article 9 ?

- **Groupe sanguin**
- **Adresse IP**
- **Empreinte digitale pour badger**
- **Salaire**

Réponse Le groupe sanguin (santé) et l'empreinte qui sert à identifier (biométrie). L'adresse IP et le salaire sont des données personnelles, mais pas sensibles au sens de l'article 9.

3

SECTION 3

Les risques

« Quand les données se retournent contre nous »

Sans protection, les données peuvent servir à…

Profiler une personne

À partir de leurs « J'aime » Facebook, un modèle a deviné l'orientation sexuelle, la religion ou les opinions politiques d'utilisateurs (Kosinski et al., 2013).

Manipuler des comportements

Cambridge Analytica (2018) : les données de 87 millions de comptes Facebook exploitées pour cibler des messages politiques.

Discriminer

Amazon abandonne en 2018 un outil de recrutement par IA : entraîné sur des CV surtout masculins, il pénalisait les candidates.

Cibler abusivement

Publicités pour le crédit rapide ou les jeux d'argent montrées en priorité aux personnes jugées vulnérables d'après leur navigation.

Usurper une identité

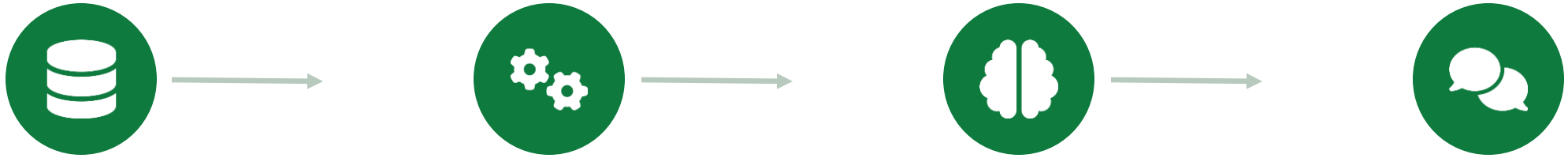
Une fuite d'e-mails et de numéros alimente l'hameçonnage (phishing) et la fraude au « faux conseiller bancaire ».

Revendre les données

Des courtiers en données (data brokers) achètent et revendent des profils détaillés, à l'insu des personnes.

D'où l'importance du RGPD.

L'IA multiplie les risques à chaque étape



Collecte

RISQUE

Aspiration massive de données en ligne (scraping)

EXEMPLE

Clearview AI : 20 M€ d'amende (CNIL, 2022) pour une base de plus de 20 milliards de photos de visages

Entraînement

RISQUE

Données réutilisées pour une autre finalité que celle annoncée

EXEMPLE

Italie, 2023 : ChatGPT suspendu un mois ; amende de 15 M€ à OpenAI (2024)

Modèle

RISQUE

Mémorisation : un modèle peut restituer des données vues à l'entraînement

EXEMPLE

Un modèle de langage peut ressortir un e-mail ou un numéro présent dans ses données

Utilisation

RISQUE

Inférence de données sensibles et fuites via les requêtes

EXEMPLE

Des salariés collent des données clients dans un chatbot public non validé

BONNE PRATIQUE

Ne jamais saisir de données clients ou de données personnelles dans un outil d'IA qui n'a pas été validé par l'entreprise.

SECTION 4

Les principes fondamentaux

« Sept règles d'or pour tout traitement »

Les sept principes fondamentaux du RGPD (art. 5)

1. **Licéité, loyauté et transparence** — informer clairement l'utilisateur
2. **Limitation des finalités** — un objectif précis, fixé à l'avance
3. **Minimisation des données** — ne collecter que le strict nécessaire
4. **Exactitude** — des données correctes et à jour
5. **Limitation de la conservation** — supprimer ou anonymiser après usage
6. **Intégrité et confidentialité** — sécuriser les données
7. **Responsabilité (accountability)** — pouvoir prouver sa conformité



Ils s'appliquent à tout traitement, quelle que soit sa taille.

Les principes appliqués : l'exemple de YallaFood

Fil rouge : YallaFood, une application (fictive) de livraison de repas.

Principe	Conforme	Non conforme
Transparence	✓ Politique de confidentialité claire à l'inscription	✗ Adresses revendues à des annonceurs sans le dire
Finalités	✓ L'adresse sert à livrer la commande	✗ L'adresse sert à calculer un score de solvabilité
Minimisation	✓ Nom, adresse, téléphone	✗ Date de naissance et religion demandées
Exactitude	✓ Le client peut corriger son adresse	✗ Le livreur est envoyé à une adresse obsolète
Conservation	✓ Historique supprimé 3 ans après la dernière commande	✗ Comptes inactifs conservés indéfiniment
Sécurité	✓ Mots de passe chiffrés, accès limités	✗ Base clients accessible à tous les livreurs
Responsabilité	✓ Registre des traitements à jour	✗ Aucune trace des choix effectués

Les six bases légales : sur quoi fonder un traitement ?

Tout traitement doit reposer sur au moins une de ces bases (art. 6) ; sinon, il est illicite.



Consentement

newsletter, cookies publicitaires



Contrat

l'adresse pour livrer une commande



Obligation légale

conserver les factures, déclarer les salaires



Intérêts vitaux

transmettre le dossier d'un patient inconscient



Mission d'intérêt public

inscriptions dans une université publique



Intérêt légitime

lutte contre la fraude, si les droits de la personne ne priment pas

UN CONSENTEMENT VALIDE EST…

- ✓ **Libre** : sans contrainte ni chantage
- ✓ **Spécifique** : pour une finalité précise
- ✓ **Éclairé** : la personne sait à quoi elle consent
- ✓ **Univoque** : un acte clair : cocher, cliquer

…et il se retire aussi facilement qu'il se donne.

☐ J'accepte de recevoir des offres

✓ **case vide par défaut** ✗ **case pré-cochée : invalide**

Piège : le consentement n'est pas la seule base, ni toujours la meilleure.

Protéger dès la conception et par défaut (art. 25)



Dès la conception

privacy by design

Intégrer la protection des données dès le premier croquis du projet, et non à la fin.

- **chiffrer les données sensibles**
- **pseudonymiser les identifiants**
- **ne prévoir que les champs utiles**



Par défaut

privacy by default

Les réglages les plus protecteurs sont activés sans que l'utilisateur ait à agir.

- **profil privé par défaut**
- **géolocalisation désactivée**
- **partage avec les partenaires désactivé**

Les quatre questions de l'ingénieur avant d'écrire la première ligne de code

Quelles données ?

Pour quoi faire ?

Combien de temps ?

Qui y accède ?

QUIZ · PRINCIPES

Une application « lampe torche » demande l'accès à vos contacts et à votre position. Quel principe est d'abord violé ?

- Exactitude
- **Minimisation des données**
- Limitation de la conservation
- Intégrité

Réponse La minimisation : une lampe torche n'a besoin ni des contacts ni de la position. Si ces données servent à autre chose (publicité), la limitation des finalités est aussi violée.

5

SECTION 5

Les droits des personnes

« Vos données vous appartiennent-elles ? »

Les droits des individus sur leurs données

Droit à l'information	savoir qui collecte, pourquoi et pour combien de temps	art. 13-14
Droit d'accès	voir quelles données sont collectées	art. 15
Droit de rectification	corriger une donnée inexacte	art. 16
Droit à l'effacement	« droit à l'oubli » : faire supprimer ses données	art. 17
Droit à la limitation	geler temporairement l'usage des données	art. 18
Droit à la portabilité	récupérer ses données pour les transférer ailleurs	art. 20
Droit d'opposition	refuser un traitement, par exemple la prospection	art. 21
Décision automatisée	ne pas être jugé par une seule machine (diapositive suivante)	art. 22

L'article 22 : quand une machine décide seule

DÉFINITION

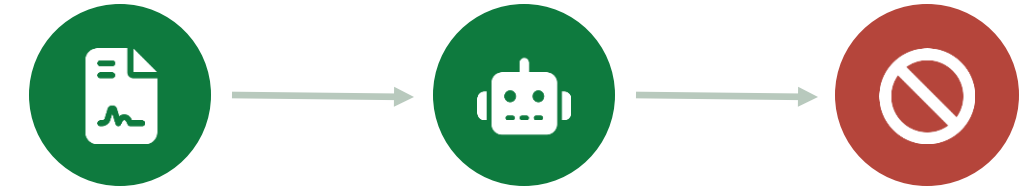
Article 22

Toute personne a le droit de ne pas faire l'objet d'une décision fondée exclusivement sur un traitement automatisé, y compris le profilage, produisant des effets juridiques ou l'affectant de manière significative.

RGPD, article 22.1

CAS RÉEL · CJUE, 7 DÉC. 2023, SCHUFA

Quand une banque s'appuie de manière déterminante sur un score de crédit calculé automatiquement par une société spécialisée, ce score constitue lui-même une décision automatisée au sens de l'article 22.



La personne peut exiger :

- une intervention humaine
- d'exprimer son point de vue
- de contester la décision

Exceptions : décision nécessaire à un contrat, autorisée par la loi ou fondée sur un consentement explicite, toujours avec ces garanties.

→ Chapitre 4 : expliquer une décision prise par une IA

Comment exercer ses droits ? Le parcours d'une demande



1. Demande

par e-mail, formulaire ou courrier, auprès de l'organisation

2. Vérification

l'organisation peut vérifier l'identité du demandeur

3. Réponse

sous 1 mois, prolongeable de 2 mois si la demande est complexe

4. Gratuité

la réponse est gratuite, sauf demande abusive

5. Recours

plainte auprès de l'autorité : CNIL, CNDP…

ESSAYEZ

La plupart des plateformes (Instagram, Spotify…) proposent un bouton « Télécharger vos informations » : vous recevez une archive de tout votre historique. C'est le droit d'accès en pratique.

CÔTÉ ENTREPRISE

Prévoir dès la conception une fonction d'export et de suppression des données d'un client : sinon, chaque demande devient un chantier manuel.

QUIZ · QUEL DROIT ?

« Je veux transférer mes playlists vers un autre service de musique. » Quel droit invoquer ?

- Droit d'accès
- **Droit à la portabilité**
- Droit à l'effacement
- Droit d'opposition

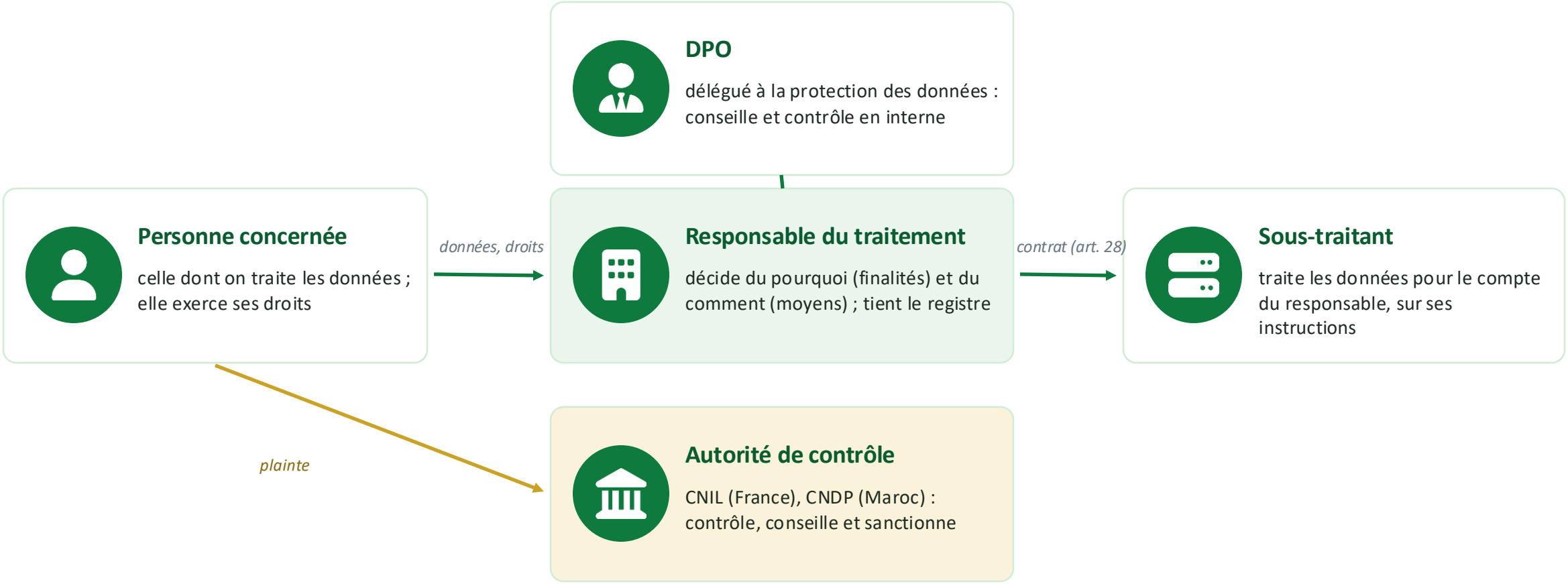
Réponse La portabilité (art. 20). Effacement : faire supprimer ses photos d'un site ; rectification : corriger une adresse erronée ; opposition : ne plus recevoir de prospection.

SECTION 6

Responsabilités et sanctions

« Qui doit rendre des comptes ? »

Les acteurs : qui fait quoi ?



Exemple : une école (responsable) confie l'hébergement de ses copies numériques à un prestataire cloud (sous-traitant).

SECTION 6 · RESPONSABILITÉS

La boîte à outils de la conformité

Registre des traitements

art. 30

la liste de tous les traitements : finalité, données, destinataires, durée de conservation

Analyse d'impact (AIPD)

art. 35

obligatoire pour les traitements à risque élevé : profilage, données sensibles à grande échelle, surveillance systématique

Contrat de sous-traitance

art. 28

fixe les obligations du sous-traitant : instructions, confidentialité, sécurité, sort des données

Mesures de sécurité

art. 32

chiffrement, contrôle des accès, sauvegardes, tests réguliers

Notification des violations

art. 33-34

prévenir l'autorité sous 72 h, et les personnes si le risque est élevé

À RETENIR

Accountability : ce n'est pas à l'autorité de prouver une faute, c'est à l'organisation de prouver qu'elle respecte le RGPD.

Violation de données : le compte à rebours de 72 heures

DÉFINITION

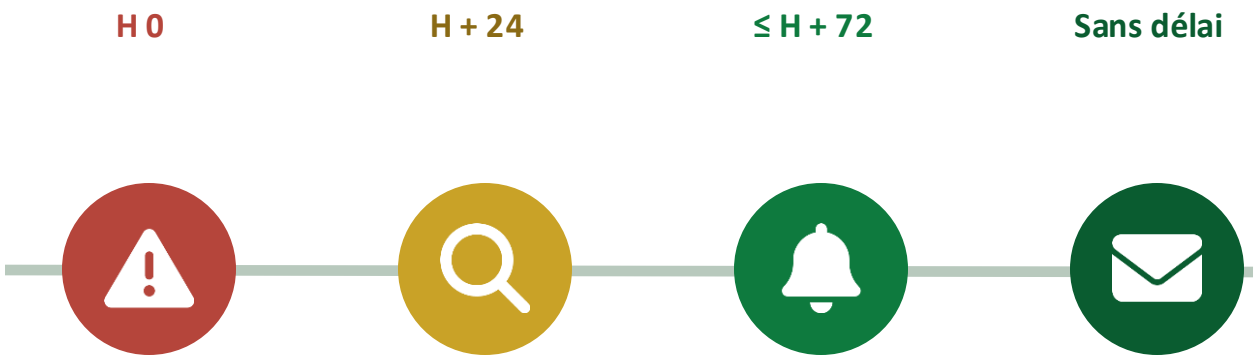
Violation de données · art. 4.12

Destruction, perte, altération, divulgation ou accès non autorisé à des données personnelles, accidentel ou illicite.

RGPD, article 4, point 12

Exemples

- ordinateur portable volé, non chiffré
- rançongiciel qui bloque le fichier clients
- e-mail envoyé au mauvais destinataire



ET TOUJOURS

Documenter chaque violation, même non notifiée, dans un registre interne.

Le délégué à la protection des données (DPO)

Ses missions

- ✓ **informer et conseiller** l'organisation et ses salariés
- ✓ **contrôler** le respect du RGPD en interne
- ✓ **conseiller sur les AIPD** et en suivre la réalisation
- ✓ **coopérer** avec l'autorité et être son point de contact

Il doit être indépendant : on ne peut ni lui donner d'instructions sur ses missions, ni le sanctionner pour les avoir exercées.

Obligatoire dans trois cas (art. 37)

Organisme public

administration, université publique, hôpital public

Suivi régulier et systématique à grande échelle

opérateur télécom, assureur, plateforme de publicité ciblée

Données sensibles à grande échelle

clinique, laboratoire d'analyses, entreprise de biométrie

MAROC

La loi 09-08 n'impose pas de DPO, mais beaucoup d'entreprises en désignent un.

Les sanctions : jusqu'à 4 % du chiffre d'affaires mondial

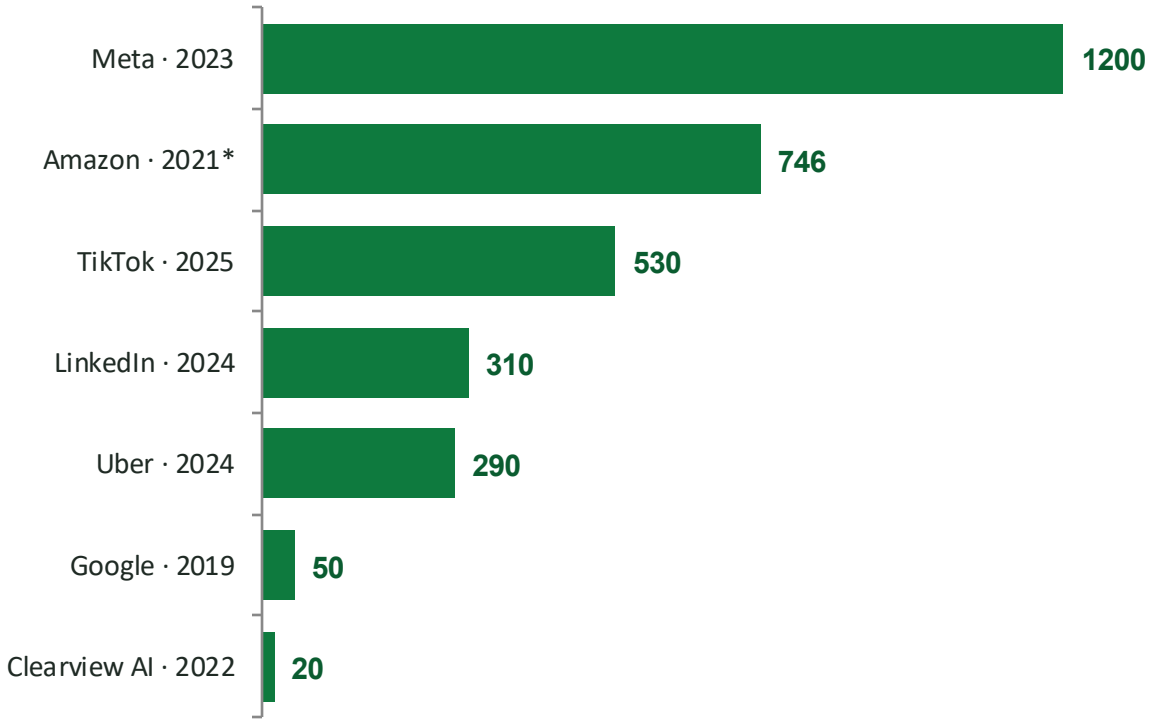
Jusqu'à 10 M€ ou 2 % du CA mondial
manquements aux obligations : sécurité, registre, notification, DPO

Jusqu'à 20 M€ ou 4 % du CA mondial
violation des principes, des bases légales, des droits ou des règles de transfert

On retient le montant le plus élevé des deux.

Au-delà de l'amende : perte de réputation et de clients, enquêtes judiciaires, actions collectives, et parfois suspension du service (ChatGPT en Italie, 2023).

Quelques amendes record (en millions d'euros)



** annulée en appel en mars 2026 pour un motif de procédure ; dossier renvoyé à l'autorité luxembourgeoise.*

QUIZ · 72 HEURES

Une entreprise découvre une fuite de données le vendredi à 18 h. Jusqu'à quand peut-elle notifier l'autorité ?

- Lundi 9 h (jours ouvrés)
- **Lundi 18 h**
- Sous 30 jours
- Seulement si un client se plaint

Réponse 72 heures calendaires après la découverte, week-end compris : lundi 18 h. Au-delà, elle doit justifier son retard ; la notification peut être complétée ensuite.